task: phase-g0-security-and-golive-blockers

created: 2026-11-02

updated: 2026-11-02

status: in_progress

workflow: WF-HOTFIX

priority: P0

PLAN MASTER: Phase G0 — Khắc phục Toàn diện Lỗ hổng An ninh Critical, Sửa lỗi `/desktop` & Cứng hóa Hạ tầng Mở Cổng Golive Tier-1 (LAN Pilot)

> File này CHỈ chứa tổng quan + trạng thái. Chi tiết từng bước (mô tả đầy đủ, Handoff Log, artifact chi tiết) nằm ở `steps/STEP-[N.M]-[tên].md` tương ứng — xem cột "Step file" bên dưới.

Mô tả

Thực thi trọn vẹn **Giai đoạn 0 (Phase G0: `G0-1` → `G0-6`)** theo quyết định kiến trúc `ADR-001` đã được CTO phê duyệt nhằm gỡ lệnh `🔴 BLOCK GOLIVE` và đạt **10/10 tiêu chí Gate 1 — Mở Golive Tier-1 (Mạng LAN Nội Bộ KZTEK / VPN)**:

- Khóa triệt để chuỗi tấn công chiếm quyền `ADMIN`, đóng tự đăng ký công khai (`/api/auth/register` & `/register`), dựng chốt chặn RBAC tập trung (`withApiAuth` + Next.js 16 `src/proxy.ts`), bảo vệ dữ liệu nội bộ Ticket và kiểm soát vòng đời phiên (`scrypt` async, `tokenVersion`, cưỡng chế `mustChangePassword`).
- Diệt tận gốc lỗ hổng Stored XSS (`isomorphic-dompurify` cho `RichMarkdown` & `WysiwygEditor`, escape HTML Email), bật `httpOnly: true` cho cookie phiên tương thích kép HTTP LAN & HTTPS Internet, mã hóa `AES-256-GCM` cho khóa tích hợp trong `SystemSetting` và xóa rò rỉ log/Git.
- Dựng Rate-Limiter chống brute-force/spam, khóa upload tệp thực thi web (`.html/.svg/.js`), bổ sung HTTP Security Headers, vá dứt điểm lỗi 404 trên `/desktop`, chống trùng mã `Task.number` bằng Transaction, cứng hóa Docker (`127.0.0.1:5432`, `/api/health`) và thiết lập sao lưu `pg_dump` tự động kèm diễn tập khôi phục thực tế.

Nguồn yêu cầu

- Yêu cầu gốc: "lên plan chi tiết xử lý" -> "tiep tuc" (căn cứ `docs/architecture/ADR-001-system-architecture-roadmap.md` & `docs/architecture/ARCH-AUDIT-system-2026-11-02.md`)
- Workflow: `WF-HOTFIX` — Hotfix Khẩn cấp An ninh & Ổn định Hệ thống (kết hợp cổng bắt buộc `security-audit-stride` và `UX/UI Reviewer` do có thay đổi giao diện `/login`, `/register`, Editor, `/desktop`)
- Agent chain: `SENIOR DEVELOPER` (Steps 1.1 → 1.3) → `TECH LEAD` (Step 2.1: Code Review + `security-audit-stride`) → `UX/UI REVIEWER` (Step 2.2: Chạy app thật & chấm C1–C7) → `QA`

`ENGINEER` (Step 3.1: Kiểm thử 10 chốt chặn Gate 1 trên app thật) → `DEVOPS LEAD` (Step 3.2: Docker Hardening + Backup/Restore Drill & Sign-off Gate 1)

Phases & Steps

> **Session isolation (GEMINI.md §16.5):** Mỗi bước ☐/🔄 PHẢI chạy tách session — LOCAL dùng `Agent` subagent, WEB dùng `RemoteTrigger`. Agent/trigger tự tạo/cập nhật step file riêng, commit+push, rồi cập nhật đúng 1 dòng status ở bảng dưới đây.

Phase 1: Khắc phục Bảo mật Lõi, Xác thực & Toàn vẹn Nghiệp vụ (`G0-1` → `G0-6a`)

#	Bước	Agent	Status	Step file	Hoàn thành lúc
---	------	-------	--------	----------	----------
1.1	**[G0-1 & G0-5] Auth/RBAC Guard, Đóng tự đăng ký & Vòng đời Token:** Thêm `User.tokenVersion` vào Prisma; đổi `scryptSync` → `scrypt` async; dựng `withApiAuth()` + `src/proxy.ts` (Next.js 16); khóa quyền `ADMIN` cho `/api/users/**` & `/email-logs`; đóng đăng ký công khai (`/api/auth/register`, ẩn/khóa UI `/login` & `/register`); bảo vệ `/api/attachments/[id]`, ẩn `internalNotes` & khóa giả mạo `isStaff` trên `/api/tickets/[ticketId]/**`; cưỡng chế `mustChangePassword` & thu hồi JWT cũ khi đổi mật khẩu	`senior-developer`	✅	`steps/STEP-1.1-auth-rbac-and-session-hardening.md`	2026-11-02 20:55
1.2	**[G0-2 & G0-3] Chống XSS `DOMPurify`, Cookie `httpOnly` (LAN/HTTPS) & Mã hóa Secrets AES-256-GCM:** Tích hợp `isomorphic-dompurify` làm `Seam` chung cho `RichMarkdown` & `WysiwygEditor`, escape HTML trong `mail.ts` & bật `rejectUnauthorized: true` mặc định cho SMTP TLS; bật `httpOnly: true`, `sameSite: "lax"`, `secure: COOKIE_SECURE === "true"` cho cookie phiên (đồng bộ `credentials: "same-origin"` ở client); mã hóa AES-256-GCM 8 trường secret của `SystemSetting`, trả `******` ở `GET /api/system/config`, chống SSRF `discordWebhookUrl`, xóa `console.log(body)` & gỡ `cookies.txt` khỏi Git	`senior-developer`	☐	`steps/STEP-1.2-xss-cookie-and-secret-encryption.md`	-
1.3	**[G0-4 & G0-6a] Rate-Limiter, An**	`senior-`	☐	`steps/STEP-`	-

	toàn Upload, Vá `/desktop` 404, Atomic `Task.number` & `/verify-pr`: Tạo `rate-limit.ts` gắn vào `/api/auth/login`, `/api/tickets/public`, `/api/upload`; chặn upload `.html/.svg/.js/.xhtml` + kiểm tra magic bytes + gắn Security Headers (`nosniff`, `CSP` cho `/uploads/*`, `X-Frame-Options`); bắt buộc `oaSecretKey` cho Zalo Webhook; sửa đường dẫn PATCH & parse `{ task }` trên `src/app/desktop/page.tsx`; bọc sinh `Task.number` trong `$transaction` có retry `P2002`; tạo `GET /api/health`; cập nhật `CODE-GRAPH.md` (R3) và chạy `/verify-pr` đạt PASS 100%	`developer`		`1.3-ratelimit-upload-desktop-and-verify.md`	

Phase 2: Kiểm định An ninh Độc lập & Đánh giá Giao diện Thực tế (Two-Eyes Review)

#	Bước	Agent	Status	Step file	Hoàn thành lúc
2.1	**[Security & Code Review] Review 2 trục & Tái kiểm định OWASP/STRIDE:** Kiểm tra `VERIFICATION REPORT`, chạy `/code-review` (Standards + Spec) trên toàn bộ thay đổi Phase 1 và thực thi đầy đủ `security-audit-stride` (OWASP Top 10 + STRIDE) xác nhận xóa sạch toàn bộ lỗi `Critical:` / `Required` của Phase G0	`tech-lead`	☐	`steps/STEP-2.1-tech-lead-security-and-code-review.md`	-
2.2	**[UI/UX Real-App Review] Kiểm tra trực quan trên App thật (C1–C7):** Chạy ứng dụng thật trên trình duyệt, chụp screenshot và đánh giá 7 tiêu	`ux-ui-reviewer`	☐	`steps/STEP-2.2-ux-ui-real-app-review.md`	-

	chí C1–C7 cho: (1) Trang `/login` & `/register` sau khi đóng tự đăng ký công khai; (2) Soạn thảo `WysiwygEditor` & hiển thị `RichMarkdown` sau khi bọc `DOMPurify`; (3) Không gian làm việc `/desktop` tạo mới và cập nhật trạng thái công việc				

Phase 3: Kiểm thử Nghiệm thu App Thật, Cứng hóa Docker/Backup & Sign-off Gate 1

#	Bước	Agent	Status	Step file	Hoàn thành lúc
---	------	-------	--------	----------	----------------
3.1	**[Real-App Security & Regression QA] Kiểm thử 10 chốt chặn Gate 1 trên App thật:** Chạy ứng dụng thật, xây dựng & thực thi script kiểm thử tự động `scripts/test_gate1_security.ts` kết hợp kiểm thử hồi quy thực tế xác minh: chặn leo thang quyền `401/403`, ẩn `internalNotes`/`isStaff`, khử payload Stored XSS, đăng nhập Cookie `httpOnly` trên HTTP LAN (`COOKIE_SECURE=false`) & HTTPS, che secret `******`, chặn upload độc hại, Rate-limit `429`, thu hồi JWT cũ (`tokenVersion`), chặn `mustChangePassword`, `/desktop` hoạt động 100% & tạo task song song không lỗi `P2002`	`qa-engineer`	☐	`steps/STEP-3.1-qa-real-app-gate1-verification.md`	-
3.2	**[Infra Hardening, Backup Drill & Gate 1 Sign-off] Cứng hóa Docker, Sao lưu `pg_dump` & Ký mở Tier-1 LAN:** Cập nhật `docker-compose.yml` (bind PostgreSQL `127.0.0.1:5432`, cấu hình `healthcheck` `/api/health` cho `app`, cấp quyền volume `/app/data`), viết script sao lưu định kỳ `scripts/backup-postgres.sh` & `.ps1` (UTF-8 BOM), chạy `pg_dump` và **diễn tập khôi phục (restore test) thực tế thành công ≥ 1 lần**, xác nhận đóng băng bản cài C# Mobile cũ (Tiêu chí #9) và ban hành Biên bản Sign-off Gate 1 mở Golive Tier-1 LAN Pilot	`devops-lead`	☐	`steps/STEP-3.2-devops-hardening-backup-and-signoff.md`	-

Artifacts dự kiến (tổng)

- [ ] Mã nguồn khắc phục toàn diện `G0-1` → `G0-6`
- [ ] `code-graph/CODE-GRAPH.md` (+ `.docx`, `.pdf` cập nhật theo Rule R3)
- [ ] `docs/architecture/SECURITY-AUDIT-gate1-2026-11-02.md` (+ `.docx`, `.pdf`)
- [ ] `docs/ux-review/UX-REVIEW-phase-g0-2026-11-02.md` (+ `.docx`, `.pdf` & bộ screenshots thực tế)
- [ ] `docs/test-cases/QA-REPORT-gate1-2026-11-02.md` (+ `.docx`, `.pdf`)
- [ ] `docs/architecture/GATE1-SIGNOFF-2026-11-02.md` (+ `.docx`, `.pdf`)

Blockers

Không có

Quyết định / Ghi chú tổng & Lộ trình 3 Plan Liên hoàn

- **Chính sách tài khoản:** Đóng đăng ký công khai (`/api/auth/register`), chỉ Admin được tạo tài khoản nội bộ. Ẩn/chặn link register ngoài UI.
- **Tương thích mạng LAN/HTTPS:** Cookie `httpOnly: true; sameSite: "lax"`, cờ `secure` phụ thuộc `COOKIE_SECURE === "true"`.
- **Lộ trình:** Plan 1 (Phase G0: Gate 1 Tier-1 LAN Pilot) -> Plan 2 (Phase G1 Backend Outbox + CI Gate) -> Plan 3 (Phase G1 Mobile Avalonia 12 + KztekComponentAvalonia).

Lịch sử cập nhật

Ngày	Cập nhật	Agent
------	----------	-------
2026-11-02	User xác nhận "tiep tuc", khởi tạo Plan 1 và bắt đầu Bước 1.1	task-planner
2026-11-02 20:55	Hoàn thành Bước 1.1: Auth/RBAC Guard, Đóng tự đăng ký & Vòng đời Token	senior-developer

Status icons: ⬜ Todo | 🔄 In Progress | ✅ Done | 🛑 Blocked | ⏭️ Skipped

Cách đọc nhanh: đọc MASTER trước → nếu cần chi tiết bước cụ thể mới mở step file tương ứng.